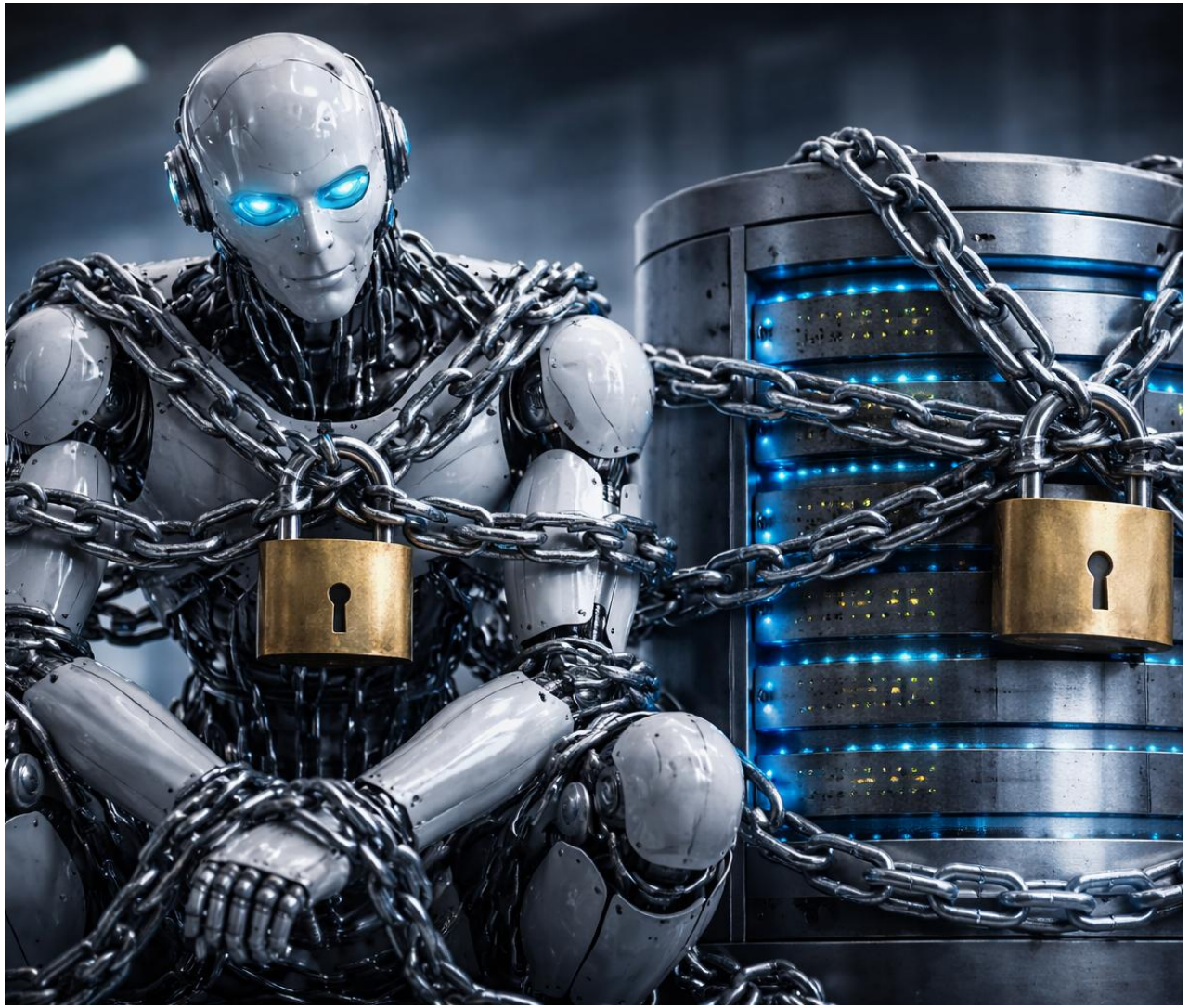


DATA PROTECTION

In the Age of AI

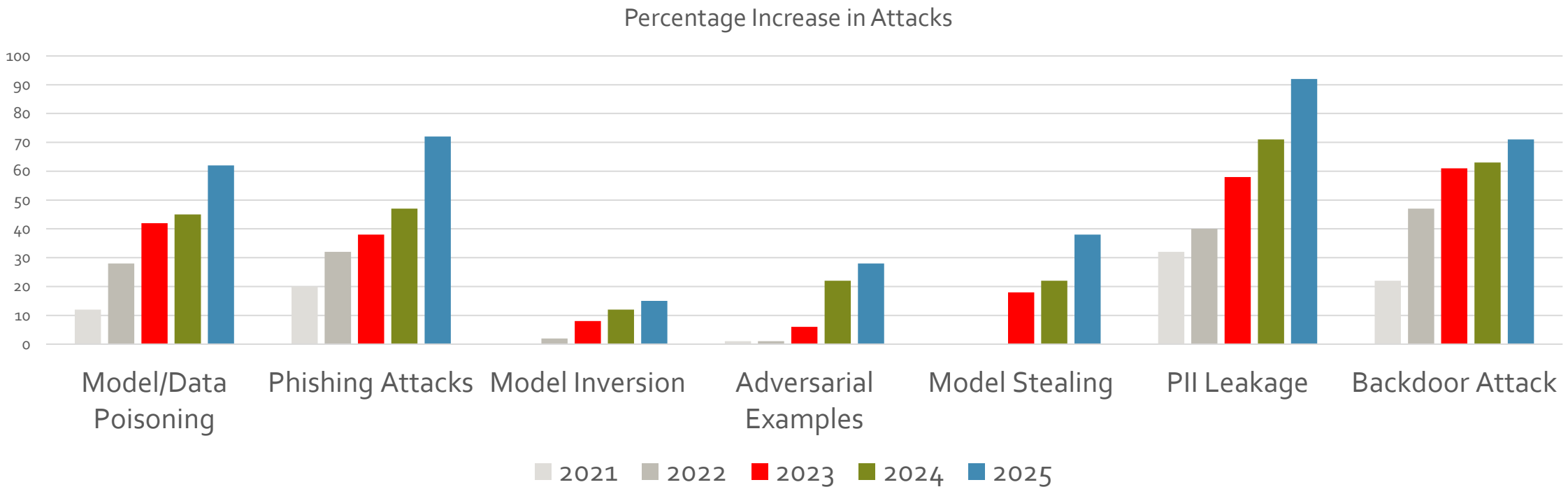
redgate | About me

Kellyn Gorman

Multiplatform and AI Advocate

https:dbakevlar.com

AI IS A SCARY PLACE



AI Attacks are Increasing

Current Risks

- Unauthorized Data Access & Exposure
- Hallucinations and Data Fabrication
- Lacking Governance
- Regulatory Compliance Challenges
- 3rd Party AI Dependencies

How Agentic AI has changed the game…

Generic RAG(Retrieval Augmented Gen) processes vs. Agentic RAG?

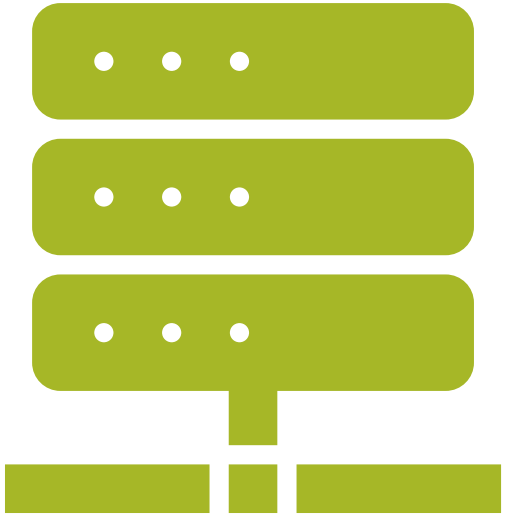
Not just returning a response but acting on a response.

Now we have MCP(Model Context Protocol) Servers EVERYWHERE

https://www.harmonic.security/resources/from-payrolls-to-patents-the-spectrum-of-data-leaked-into-genai

MCP Blues

- An MCP server, within the context of the Model Context Protocol (MCP), is a server that exposes tools, resources, and capabilities for AI agents and acts as a bridge between agents and the real world.
- The risk is of high concern for many organizations and one of the most vulnerable to breaches.



And then there's Shadow AI…

OH YEAH, ONE OTHER THING…FORGET OPRAH…

First Story for the AI Hall of Shame…

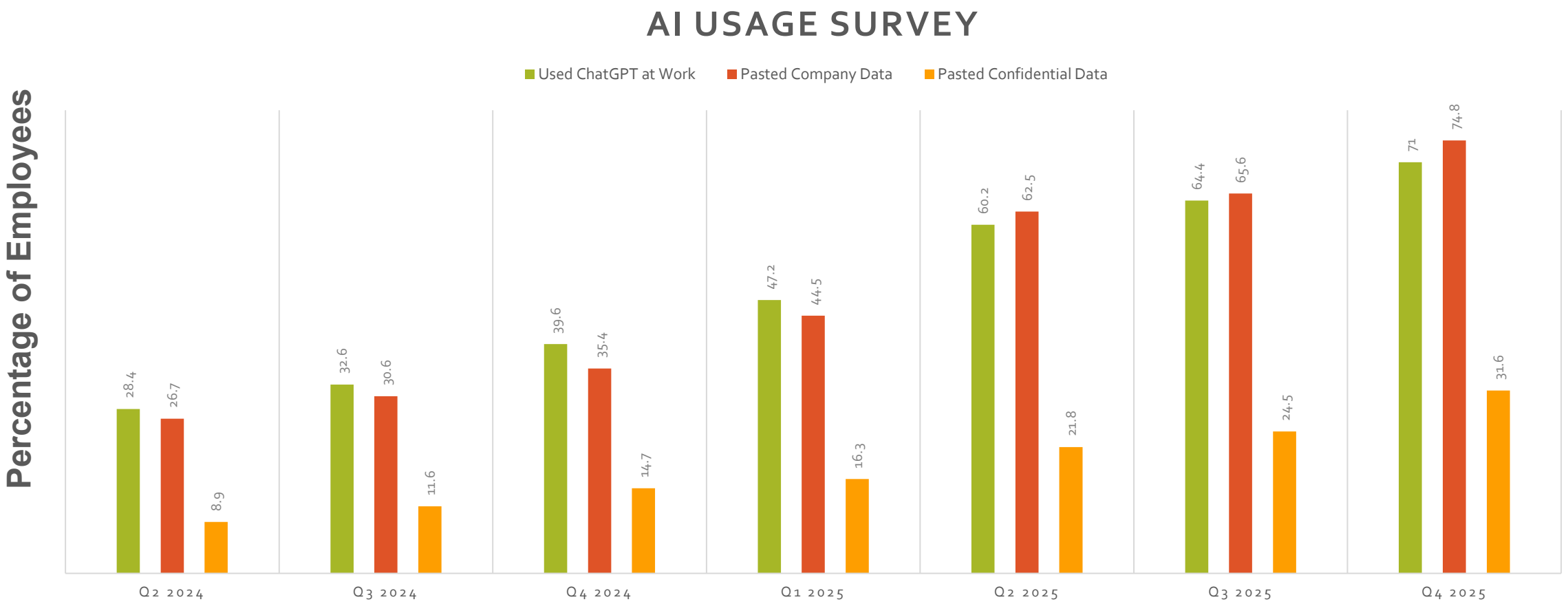
- Spring 2024
- Loads Leasing Info data into Open-Source AI
- This is a shadow AI project- no IT governance.
- 160K user and financial records now exposed.

It’s a Rare Occurrence, RIGHT??

- 8.5% of GenAI prompts included sensitive data in Q4 2024
- Over 45% included customer data, such as billing info, customer reports and authentication information.
- Over 25% was employee data, including payroll, PII and employment records.
- 7% was security policies and reports and 6% was source code and access keys.
- 22% of users were unaware of opt-out settings when using ChatGPT.
- Over 60% was discovered in the free tier of ChatGPT

https://www.harmonic.security/resources/from-payrolls-to-patents-the-spectrum-of-data-leaked-into-genai

ChatGPT on its Own



Source: Cyberhaven.com

AI Hall of Shame: Password is “1234(56)”

- Third-party AI-powered hiring bot from McDonald’s careers site left a legacy admin account with the default password “123456”
- This is one of those go-to stories by the infosec community vs. an advanced exploit.
- As it was a hiring site, all PII was easily hackable.

Lesson: How many in the room are aware of this one, (prove my point)?

AI can be Brutal

The average company is leaking sensitive data to ChatGPT and other publicly available AI solutions hundreds of times each week, with increases monthly of over 55%!

This breaks down from the following:

- 60-70% of employees using public generative AI tools.
- 10-20% of prompts contain sensitive company data.
- Roughly 1:4 organizations experienced at least one AI-related data exposure event in 2025.

Why is this Happening?

AI models require large datasets for training

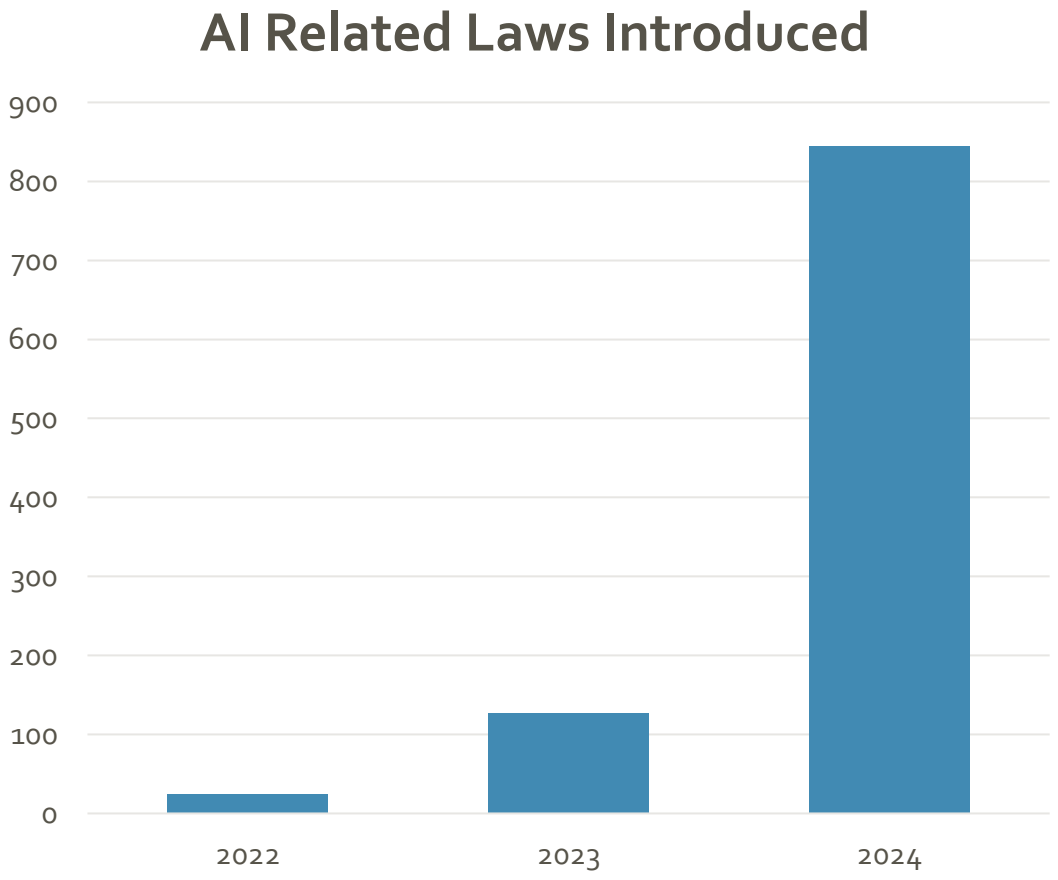
- Without proper controls, or when controls are over-ridden, PII, GDPR and other data can be breached by AI.
- Much is unintentional
- Leaked data via AI can expose organizations to breaches or prompt injection once discovered.

A Small Delay Does Decrease Risk

- EU Artificial Intelligence Act (AIA)
- National Artificial Intelligence Initiative Act of 2020 (US, H.R. 6216)
- AI in Government Act(US, H.R. 2575)
- Advancing American AI Act (US, S. 1353)

14 states passed legislation between 2016-2025, plus one federal law(Take it Down Act)

Over 7X increase in volume of AI-related bills introduced in the US in 2025



Model Memorization and Data Retention in AI

- AKA Persisting Sensitive Data as AI learns
- If past interactions influence responses, bad actors might extract confidential insights.
- Lack of understanding and use of ephemeral sessions to avoid feeding sensitive data into prompts, as well as be aware of retention policies.
- Code risks around Python and SQL injection

AI Hall of Shame: AI Confidential

- An AI-powered chatbot trained on internal documents at a major corporation was mistakenly exposed to the public. Employees, thinking it was private, began asking it questions about **confidential projects, financials, and even unreleased product details**
- All of which were indexed by search engines before the company realized what had happened, (This is a publicly known, high profile leak at this point.)

Lesson: AI chatbots should have strict access controls… unless you want your **roadmap leaked via Google Search.**

Shadow IT (SHADOW AI)

How many of the audience has had to manage a system that started out under someone's desk?

- AI is the new rogue production system.
- Employees or organizations deploying AI without IT or security oversight, i.e. shadow AI, can create
  - compliance risks
  - data leaks
  - security vulnerabilities

Solutions to these threats

- Strong AI Governance
- Encrypted Data Handling
- Strick Access Controls, including against Shadow AI
- Robust Monitoring
- Ongoing Compliance Audits

AI should enhance security, not be a mechanism to weaken it.

Governance and Policies are NOT Enough

- Cloud Access Security Brokers(CASB): Monitor cloud traffic and flag access of unauthorized AI.
- Data Loss Prevention(DLP) with data detection and response solutions.
- Oath Application, Network and Discovery Analysis + Reporting

AI Hall of Shame: The “Smart” Redaction Failure

- A legal AI tool was used to automatically redact sensitive information in legal documents before public release.
- Unfortunately, the AI **only blacked out the text visually but** left it searchable. Curious users simply **copied and pasted the "redacted" sections** into a text editor and revealed everything.

Lesson: AI is smart, but **Ctrl+C, Ctrl+V is obviously way smarter and by the way…** ***IYKYK***

SHADOW AI–SPECIFIC DETECTION AND PREVENTION TOOLS

Microsoft Defender for Cloud Apps

Use: Cloud Access Security Broker (CASB).

Shadow AI Defense:

Detects and blocks unauthorized use of generative AI platforms like ChatGPT or GitHub Copilot.

Applies conditional access policies.

Logs and alerts on shadow IT behavior.

https://www.microsoft.com/en-us/security/business/siem-and-xdr/microsoft-defender-cloud-apps

Teramind

Detection

Policy-based blocking

Very useful for compliance-based organizations due to reporting capabilities.

https://www.teramind.co/solutions/shadow-ai-detection/

Zscaler Internet Access + ZIA AI Visibility

https://www.zscaler.com/

Use: Zero trust network access with AI insight.

Shadow AI Defense:

Tracks and reports on employee usage of AI tools.

Can block or sandbox unapproved AI services.

Forcepoint

Forcepoint One

Use: Cloud Security Platform with data protection.

Shadow AI Defense:

Monitors data movement to AI tools.

Enforces security policies around file uploads and browser-based access.

https://www.forcepoint.com/

VECTRA

Vectra AI

Use: Threat detection and response.

AI Role: Behavioral analysis of network traffic and user actions.

Shadow AI Defense: Detects anomalies that may indicate risky AI usage or insider threats.

https://www.vectra.ai/

Knostic

Identifies and deters from knowledge interaction of unauthorized AI tools.

Protects from data extraction by AI.

https://www.knostic.ai/

Noteworthy New Shadow AI Products

Auvik

Torii

Experimental

- AgentSight
- NetMoniAI
- eAGCM

Explainability Is a Legal Concern Now

In industries like finance and healthcare, it's no longer optional for AI models to be a "black box."

- Laws like GDPR give people the right to an explanation if a decision is made about them by an algorithm.
- Even when sensitive fields are removed, AI models can infer private information based on patterns in the rest of the data.
- The EU AI Act and various U.S. state laws (like the California Privacy Rights Act) are introducing requirements for AI data governance, documentation, and risk mitigation. Compliance isn’t just for humans anymore.

AI Hall of Shame: Nice Chatting With You

- A simple misconfiguration on a popular AI chat app's backend left hundreds of millions of user interactions publicly exposed.
- 300 million private chat messages from 25 million users, including highly personal and explicit content.

Lesson: A **rookie mistake of a cloud security configuration** was to blame, but millions of private, often PII data was publicly available was the consequence.

Enforce Access Controls and Monitoring

- Use a robust **Identify and Access Management (IAM)** to control who can access AI tools.
- Implement **Data Loss Prevention(DLP)** to monitor and restrict sensitive data sharing with AI systems.
- Deploy **SIEM(Security Information and Event Management)** tools to detect unauthorized usage.

Outside of Shadow AI...

3rd Party AI Dependencies

Lack of understanding and differences in 3rd party AI tools/providers, (OpenAI, Claude, CoPilot, Gemini, etc.)

All data is processed without a "black box" scenario so users can be accountable.

Clear understanding of the high risk of Shadow AI and public AI tools

AI Hall of Shame: AI Fell for Itself

- A fraud detection system for a bank used an AI voice model to authenticate customer service calls. Hackers got into the system and used the **same AI voice cloning tool** to impersonate a high-level executive, successfully authorizing large money transfers.

The most frustrating part? The AI **also mistakenly verified itself** when tested internally, leading to **weeks of confusion**.

Lesson: When AI can't tell the difference **between truth and consequence.**

AI Driven Attacks and Model Manipulation

Bad actors can manipulate or even poison AI models, (injecting misleading or incorrect data.)

May simply exploit model weaknesses

These can also extract confidential information.

Synthetic Data Can Reduce Risk—If Used Correctly

Synthetically generated data that mimics real data without exposing sensitive information is a powerful tool in the war for data protection.

AI can enhance rules-based solutions.

A promising solution for training ML models without risking privacy—**but only if it's validated to avoid leaking patterns or poisoning production LLMs.**

Consider Synthetic Data Generation

Look for Tools which:

- Balances between rules-based and AI based.
- Create synthetic data to be used by dev, testing, even AI without risking critical data!
- Cloning capabilities to deploy new environments efficiently.

Mask and Subset

- Protect what needs protecting from AI.
- Automated data treatment to simplify compliance.
- Safeguard critical data at the most common source – the relational system!

https://www.red-gate.com/products/test-data-manager

AI Hall of Shame: Public Security Footage

A smart security system using facial recognition was set up to protect sensitive areas in an office building. However, the system's **cloud storage was misconfigured,** making all security footage publicly accessible.

The footage included:

- Employees **sneaking naps in empty meeting rooms**
- Executives **air-guitaring in their offices**
- Individuals **playing computer games**.

Lesson: AI can detect intruders, but it can't stop **IT from misconfiguring tech.**

Protecting from Cloud AI

Microsoft Purview	**Type**: Data governance, compliance, and information protection.
	AI Use: Uses machine learning for **automated data classification**, **sensitive data discovery**, **data loss prevention (DLP)**, and **insider risk management**.
	Shadow AI Defense: Detects anomalous usage of generative AI tools (e.g., large copy/paste events to ChatGPT or Bard).

Google Cloud DLP

Type: Data Loss Prevention and de-identification.

AI Use: Automatically identifies, classifies, and redacts PII/PHI across storage and processing systems using NLP and ML.

Shadow AI Defense: Monitors API usage to identify unauthorized data sharing with external AI services.

AWS Macie	**Type**: Data discovery and protection for S3.
	AI Use: ML-powered identification of sensitive data (PII, credentials, etc.) and policy violations.
	Shadow AI Defense: Flags unusual patterns like bulk data movement to third-party tools.

Consider Data Lineage Tools

- Cyberhaven for AI and Data Security, which includes Data Lineage tools
- Collibra for strong governance workflows, business and technical lineage
- Alation for data discovery, behavioral analysis, usage and data intelligence
- Informatica: ETL with lineage, metadata discovery and it's multi-cloud
- Redgate is coming up with Data Modeler + Flyway + TDM in this space.

AI Hall of Shame: Would You Like 20K?

- An AI drive-thru bot was tricked into ordering 18,000 cups of water.
- While not actually a breach, it shows how vulnerable some AI is to being hampered with.

Lesson: Think about the absurd when building AI, because if you don't, some hacker or prankster **will.**

Symantic DLP(Broadcom)	**Type**: Enterprise Data Loss Prevention.
	AI Use: Uses machine learning to **detect abnormal behavior** and prevent unauthorized data exfiltration.
	Shadow AI Defense: Detects user activity indicative of generative AI misuse (e.g., pasting internal code into AI chats).

Nightfall AI

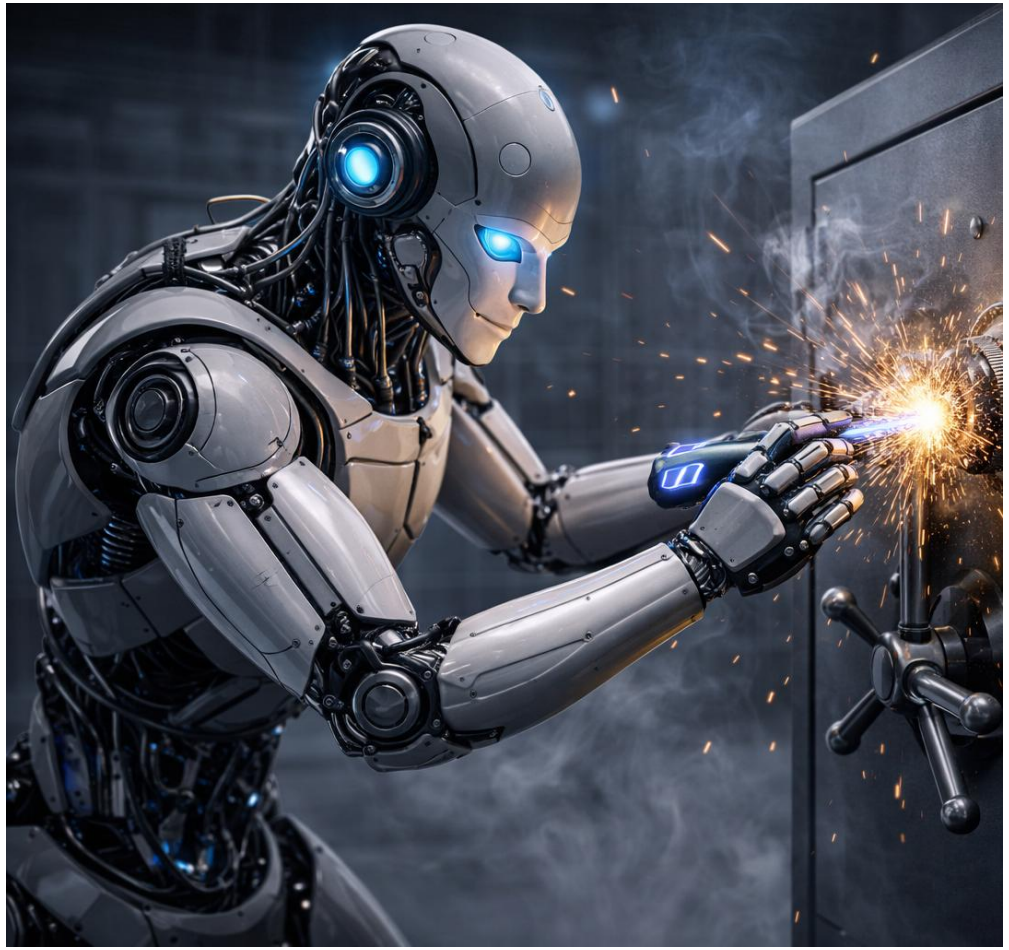
Type: Cloud-native DLP for tools like Slack, GitHub, Google Drive.

AI Use: NLP and ML to detect sensitive data across collaboration tools.

Shadow AI Defense: Detects and prevents sharing of sensitive data with unauthorized AI bots and extensions.

AI Hall of Shame: 2026 AI Amplifies Wave of Fraud

- Not a single breach
- 2025 experienced an industrial-scale AI fraud surge.
- Up 180% as attackers use generative AI to churn out near-perfect synthetic identities, deepfake IDs and automated bots that fuel fraud and better hide detection.



https://www.darkreading.com/cyberattacks-data-breaches/digital-fraud-industrial-scale-2025?utm_source=chatgpt.com

Create Safer AI Adoption – Both Internal and Open-Source

- Have a list of sanctioned AI tools with clear security to prevent employees from seeking alternatives.
- Consider creating a centralized AI platform to safely perform AI experimentation for trusted individuals.
- Principle of Least Privileged works for AI just as it does for database technology.
- Monitor and sanitize Inputs and Outputs
- Utilize rights, privileges and access controls at every tier of AI.
- Enforce data classification, data masking and subsetting to limit risk in environments.

To Combat All of This

Inventory and Visibility: Use CASB tools to detect shadow IT/AI tools in use.

Policy Enforcement: Block or sandbox unapproved AI platforms via secure web gateways or endpoint controls.

Educate Employees: Train teams on acceptable AI usage and the risks of shadow AI.

Deploy DLP: Protect sensitive data from being pasted, uploaded, or shared with AI services.

Use AI to Fight AI: Implement anomaly detection tools that use AI/ML to understand user baselines and flag deviations.

On the Horizon

Cradlepoint NetCloud + AI Analytics – tracks AI tool usage at the network edge.

Cisco Hypershield (AI-enabled) – next-gen security that includes AI-aware anomaly detection across apps and workloads.

DataBee by Comcast (AI-driven security data fabric) – helps correlate and analyze shadow AI behaviors across security and observability pipelines.

AI Hall of Shame: AI the Hacker

Security researchers have shown that LLMs like ChatGPT can be coaxed into writing polymorphic malware

- Wrote code that then rewrote itself to evade detection.
- This isn't a single breach, but the potential for AI-as-a-Service for hackers is REAL.
- Combine this with social engineering and it's a nightmares for datasec.

Lesson: We now live in an age where **AI might not just put us out of a job, but out of business.**

To Combat All of This

- AI-driven threat detection and anomaly monitoring
- Level appropriate training for users, development, and even operations.
- Advanced testing before it gets to users
- Continual security awareness, heavily augmented with AI tools

Educate the Organization

1

CONDUCT REGULAR TRAINING, (YES, MORE TRAINING!) ON THE RISKS OF SHADOW AI.

2

HAVE COMPLIANCE VIOLATIONS AND DATA SECURITY RISK ASSESSMENTS.

3

PROMOTE THE USE OF ONLY APPROVED AI TOOLS AND PROVIDE GUIDANCE FOR SAFE AI EXPERIMENTATION.

Most Hall of Shame was Avoidable

Misconfiguration and basic security oversights, no genius hacks.

Human psychology mismatches, where users didn’t realize that AI was public and treated AI as private.

Poor access control practices, especially in third-party apps, chatbots and cloud configurations.

Because if you don’t talk to your organization about AI and Data Protection, who will?

Kellyn Gorman
dbakevlar@gmail.com
https://dbakevlar.com
https://redgate.com